

SECURITY INCIDENT REPORT

Unauthorized Remote Access and Multi-Vector Persistence — NPT-WS01

Lab exercise. This report documents a guided threat-hunting exercise against simulated Microsoft Defender telemetry in a shared training workspace. It is not a record of a live incident, and no production systems or real data are represented. It is presented for the investigative methodology and the response reasoning.

Field	Value	Field	Value
Ticket	#4451	Classification	Confirmed Incident
Reported	22 Apr 2026, 09:14 UTC	Severity	High
Reporter	Mark Smith, Finance	Category	Intrusion / Persistence
Primary host	NPT-WS01	Status	Containment proposed
Secondary host	NPT-SRV01 (impacted)	Framework	NIST SP 800-61r2
Stated focus window	22 Apr 2026, 04:30–06:00 UTC	Analyst	SOC Tier 2
Observed activity	from 22 Apr 2026, 00:37 UTC	Exercise	Lab / simulated telemetry

Executive Summary

An external actor authenticated to NPT-WS01 over the network using the shared service account 'helpdesk' from the public IP address 20.110.92.50. The intrusion followed a password-guessing campaign that generated repeated authentication prompts on the user's workstation overnight — the symptom the user reported and dismissed.

Once authenticated, the actor executed commands remotely via WMI, staged an implant named WindowsUpdate.exe in C:\Windows\Temp\, and established command-and-control communication with updates.abordasync.website. The actor then installed four independent persistence mechanisms and created a privileged backdoor account. A second host, NPT-SRV01, raised a command-and-control alert with an evidence role of 'Impacted', confirming the intrusion was not confined to the originally reported workstation.

Key judgement: This is a confirmed hands-on-keyboard intrusion, not a false positive or benign administrative activity. The volume and redundancy of persistence mechanisms indicate the actor intended to retain long-term access. Because a second host was targeted, containment must be treated as a fleet-level action rather than a single-machine cleanup.

The user's report of 'seems fine this morning' is consistent with the attack succeeding: the authentication prompts stopped because the actor gained access, not because the activity ceased.

Confirmed Indicators of Compromise

All values below were recovered from Microsoft Defender Advanced Hunting across the 22 April 2026, 02:00–08:00 UTC query window and validated against the host NPT-WS01.

#	Artifact Type	Source Table → Column	Value
1	Compromised account	DeviceLogonEvents → AccountName	helpdesk
2	Attacker source IP	DeviceLogonEvents → RemoteIP	20.110.92.50

#	Artifact Type	Source Table → Column	Value
3	Execution command	DeviceProcessEvents → ProcessCommandLine	cmd.exe /Q /c start "" "C:\Windows\Temp\WindowsUpdate.exe"
4	Parent process	DeviceProcessEvents → InitiatingProcessFileName	wmiprvse.exe
5	C2 domain	DeviceNetworkEvents → RemoteUrl	updates.abordasync.website
6	Implant SHA256	DeviceFileEvents → SHA256	20cef6a013953890f9d38605d25d60dd63b42b09946bbb18ddb4a456da306e77
7	Run-key value	DeviceRegistryEvents → RegistryValueName	WindowsHealthCheck
8	Scheduled task	DeviceProcessEvents → ProcessCommandLine	GoogleUpdaterTask
9	Malicious service	DeviceProcessEvents → ProcessCommandLine	WindowsHealthSvc
10	Backdoor account	DeviceProcessEvents → ProcessCommandLine	nexus_admin
11	Impacted second host	AlertEvidence → DeviceName	npt-srv01

Evidence note: The captured command line for artifact 3 terminates at the output redirection operator. Impacket's wmiexec module conventionally redirects command output to a file on the ADMIN\$ share for retrieval over SMB. The redirection target was not recoverable from the available telemetry and is therefore not asserted here; it should be confirmed during forensic imaging.

D2 — Investigation Report

This section follows the NIST SP 800-61 Revision 2 incident response lifecycle. Phase 1 (Preparation) is addressed in the Lessons Learned section, as the relevant preparation gaps are best understood after the attack narrative.

Phase 2 — Detection and Analysis

2.1 Detection Point and Why It Was Chosen

The investigation began at authentication rather than at malware execution. This was a deliberate choice, and it is the single most important methodological decision in this hunt.

The reported symptom — repeated login prompts overnight — is an authentication-layer artifact. Starting anywhere else would have required guessing. More substantively, in an intrusion where the actor holds valid credentials, every subsequent action is technically authorized. Process execution, file writes, and service installation all appear legitimate in isolation because a permitted account performed them. The only point at which the activity is unambiguously anomalous is the moment a credential is used from a place it should never be used from.

Filtering `DeviceLogonEvents` to successful logons in the window and isolating network logons (`LogonType 3`) produced a small result set. Within it, the `helpdesk` account authenticating from the public address `20.110.92.50` was immediately disqualifying: an internal support account has no legitimate reason to authenticate from the public internet.

This detection point also produced the two pivots that drove the rest of the investigation — an account name and a source IP. Every subsequent flag was reached by pivoting on one of those two values. A detection point that yields strong pivots is worth more than one that merely yields an alert.

Alternative detection points considered. Starting from the implant hash would have found the malware but not the entry vector, leaving the credential compromise unaddressed and the host open to immediate reinfection. Starting from the C2 domain would have confirmed egress but not attribution to an account. Both were viable; neither would have scoped the incident correctly.

2.2 Attack Chain Reconstruction

Initial access. The actor authenticated to NPT-WS01 as `helpdesk` from `20.110.92.50` using a network logon. The overnight prompt activity reported by the user is consistent with password guessing or spraying preceding the successful logon. The credential was valid, so no exploit was required.

Execution. Commands were executed remotely via Windows Management Instrumentation. The observed command line, `cmd.exe /Q /c start "" "C:\Windows\Temp\WindowsUpdate.exe"`, carries the signature pattern of Impacket's `wmiexec` module: quiet mode, single-command execution, and output redirection. The parent process `wmiprvse.exe` (the WMI Provider Host) confirms this was remote WMI execution rather than a local user session. A logged-in human running commands produces a parent of `explorer.exe` or a shell; `wmiprvse.exe` as the parent of `cmd.exe` is not normal user behaviour.

Defence evasion. The implant was named `WindowsUpdate.exe` and staged in `C:\Windows\Temp\` — a masquerading choice intended to survive casual inspection of running processes. The naming convention is repeated across every persistence artifact (see 2.3), indicating a consistent tradecraft rather than opportunistic naming.

Command and control. The host beacons outbound over port 443 to `updates.abordasync.website`, which resolves to the same address used for initial access. Reusing one address for both inbound access and C2 is operationally convenient for the actor and useful for defenders: it means a single network block disrupts both channels. The domain name continues the update-service masquerade, and TLS on 443 blends the traffic with ordinary web activity.

Privilege escalation. A local account named `nexus_admin` was created and added to the local Administrators group seconds later. The two events are correlated and close enough in time to indicate scripted rather than interactive execution. This account provides the actor with access that survives remediation of the helpdesk credential — it is an independent foothold, not a convenience.

Lateral movement. A second host, `npt-srv01`, raised a command-and-control alert with an evidence role of 'Impacted', mapped to Application Layer Protocol (T1071), Command and Scripting Interpreter (T1059), Ingress Tool Transfer (T1105), and Exploitation for Client Execution (T1203). The actor did not confine themselves to the initially reported workstation.

Establishing this required widening the hunt rather than deepening it. Every prior query filtered to NPT-WS01; this one deliberately removed that filter. It is worth noting what did not corroborate the finding: neither the C2 domain in DeviceNetworkEvents nor either compromised account in DeviceLogonEvents appears on NPT-SRV01. The implant had not been deployed there in the same form, which is consistent with movement in progress rather than a completed second compromise — and is the reason the containment plan isolates NPT-SRV01 pending investigation rather than remediating it against a known artifact list.

2.3 Persistence Analysis

Four independent persistence mechanisms were established. This redundancy is the strongest single indicator of intent in the entire dataset: an actor who installs one mechanism may be opportunistic, while an actor who installs four expects at least three to be discovered and removed.

Mechanism	Artifact	Trigger	Masquerade
Registry Run key	WindowsHealthCheck	User logon	Windows health task
Scheduled task	GoogleUpdaterTask	Task schedule	Google updater
Windows service	WindowsHealthSvc	System boot	Windows health service
Local admin account	nexus_admin	Interactive/remote logon	None — direct access

The first three all point at the same implant binary in `C:\Windows\Temp\`. Removing the binary without removing all three launch points leaves broken autoruns that will be re-armed if the actor regains access; removing the launch points without removing the binary leaves the payload in place. Both must be eliminated together, which is why the eradication sequence in D1 is ordered rather than presented as a checklist.

The fourth mechanism is categorically different. A privileged local account does not depend on the implant and will not be found by scanning for the file hash. It is the mechanism most likely to be missed and the one that would most completely undo the remediation.

2.4 Impact and Scope Assessment

Dimension	Assessment
Confirmed compromised	NPT-WS01 — full compromise with SYSTEM-level persistence and confirmed C2.
Confirmed impacted	NPT-SRV01 — command-and-control alert (T1071, T1059, T1105, T1203) with evidence role 'Impacted', 22 Apr 00:37 UTC. Extent of compromise on this host not yet established.
Credentials affected	helpdesk (compromised, used by actor); nexus_admin (attacker-created); any credential cached on NPT-WS01 must be assumed exposed.
Confidentiality	Assume compromised. Interactive access with administrative rights was held for at least 90

Dimension	Assessment
	minutes. Data staging was not directly observed but cannot be excluded — absence of evidence in EDR telemetry is not evidence of absence.
Integrity	Compromised on NPT-WS01. Registry, service configuration, scheduled tasks, and local group membership were all modified.
Availability	No impact observed. No ransomware, encryption, or destructive activity detected.
Business context	The reporting user is in Finance, raising the sensitivity of any data resident on or accessible from the host. Finance workstations commonly hold or access payment and banking systems.
Dwell time	Minimum 5 hours 23 minutes — from the NPT-SRV01 alert at 00:37 UTC through the close of observed activity at 06:00 UTC. This exceeds the 90-minute stated focus window and remains a lower bound.

The stated focus window understates the incident. The 04:30–06:00 UTC window was provided as an investigative starting point. It does not bound the activity. The command-and-control alert on NPT-SRV01 is timestamped 00:37 UTC — nearly four hours before the window opens — which means attacker activity on a second host preceded the period under examination. The password-guessing reported by the user also began earlier in the night.

This matters operationally, not just as a correction: an analyst who accepts a provided time window as the scope of an incident will systematically under-report dwell time and may miss the true entry point entirely. Retrospective hunting across a substantially wider window is required before this incident can be declared scoped, and every figure in the table above should be read as a lower bound.

2.5 MITRE ATT&CK Mapping

Tactic	Technique	Evidence
Credential Access	T1110 — Brute Force	Overnight authentication prompts reported by user
Initial Access	T1078.003 — Valid Accounts: Local	helpdesk logon from 20.110.92.50
Execution	T1047 — WMI	wmiprvse.exe spawning cmd.exe
Execution	T1059.003 — Windows Command Shell	cmd.exe /Q /c launching the implant
Defense Evasion	T1036.005 — Masquerading: Match Legitimate Name	WindowsUpdate.exe in Windows\Temp
Persistence	T1547.001 — Registry Run Keys	WindowsHealthCheck
Persistence	T1053.005 — Scheduled Task	GoogleUpdaterTask
Persistence	T1543.003 — Windows Service	WindowsHealthSvc
Persistence	T1136.001 — Create Account: Local	nexus_admin
Priv. Escalation	T1078.003 — Valid Accounts	nexus_admin added to Administrators
Command & Control	T1071.001 — Web Protocols	HTTPS beacon to updates.abordasync.website
Command & Control	T1105 — Ingress Tool Transfer	Alert technique on npt-srv01
Execution	T1203 — Exploitation for Client Execution	Alert technique on npt-srv01
Lateral Movement	T1021 — Remote Services	C2 alert, evidence role 'Impacted', on npt-srv01

D1 — Containment, Eradication and Recovery Plan

Actions are sequenced deliberately. Executing them out of order — most commonly by cleaning the workstation before disabling the compromised credential — allows the actor to observe the response and re-establish access while remediation is still underway.

Phase 3 — Containment

3.1 Immediate Actions (0–30 minutes)

1. **Isolate NPT-WS01.** Use Defender for Endpoint 'Isolate Device' (full isolation, not selective). This severs the C2 channel while preserving the host and its volatile memory for forensic collection.
2. **Isolate NPT-SRV01.** This host raised a command-and-control alert with evidence role 'Impacted'. The extent of compromise is not yet established, and treating an unscoped host as clean is the most common containment failure.
3. **Disable the helpdesk account.** Disable rather than delete — deletion destroys the audit trail. This is the actor's primary access path and must be closed before any cleanup begins.
4. **Disable nexus_admin.** The attacker-created backdoor. Disabling this before touching the implant prevents the actor from simply logging back in to reinstall it.
5. **Block the network indicators.** Add 20.110.92.50 and updates.abordasync.website to perimeter firewall and DNS blocklists, and create custom indicators in Defender. Blocking both is necessary even though they resolve to the same host, because the domain can be repointed.

Preserve before you clean. Capture a memory image and triage collection from both hosts before eradication begins. Every eradication step below destroys evidence. If the incident may result in law enforcement involvement, insurance claims, or regulatory notification, this step is not optional.

3.2 Containment Indicators to Deploy

Indicator	Value	Action
IP address	20.110.92.50	Block inbound and outbound
Domain	updates.abordasync.website	Block / sinkhole at DNS
File hash (SHA256)	20cef6a013953890f9d38605d25d60dd63b42b09946bbb18ddb4a456da306e77	Block execution fleet-wide
File path	C:\Windows\Temp\WindowsUpdate.exe	Alert on creation
Account	helpdesk	Disable, then audit all usage
Account	nexus_admin	Disable, then remove

Hunt before you assume containment held. Deploy the file hash as a fleet-wide indicator and query all hosts for it, for the C2 domain, and for the account name nexus_admin. Containment is not complete until you have confirmed the artifacts exist nowhere else. Two hosts are confirmed; that is a floor, not a ceiling.

Phase 4 — Eradication

Remove every persistence mechanism before removing the implant binary. Reversing this order leaves autoruns pointing at a deleted file, which is both a detection signal for the actor and a re-arm point if access is regained.

4.1 Registry Run Key

```
reg delete "HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run" /v WindowsHealthCheck /f
```

Check the per-user hive as well (HKCU), and verify the value data pointed at the Temp implant before deleting.

4.2 Scheduled Task

```
schtasks /delete /tn "GoogleUpdaterTask" /f
```

Export the task XML before deletion — the action, trigger, and run-as context are evidence.

4.3 Windows Service

```
sc stop WindowsHealthSvc  
sc delete WindowsHealthSvc
```

Record the binPath before deletion to confirm it referenced the Temp implant.

4.4 Backdoor Account

```
net localgroup Administrators nexus_admin /delete  
net user nexus_admin /delete
```

Remove from the privileged group first, then delete the account, so that a failure at the second step does not leave a privileged account in place.

4.5 Implant Binary

Remove C:\Windows\Temp\WindowsUpdate.exe (SHA256 20cef6a0...306e77) only after a forensic copy has been preserved. Submit the sample for analysis; the capability of the implant determines how much of the impact assessment above needs revision.

4.6 Credential Remediation

- **Reset the helpdesk credential** and — more importantly — determine why a shared support account was reachable from the public internet with a guessable password.
- **Reset every credential cached on NPT-WS01**, including the reporting user's. Administrative access implies credential material was accessible.
- **Reset credentials on NPT-SRV01** on the same basis, pending scope confirmation.
- **Audit for additional unauthorized accounts** across both hosts and the wider domain. An actor who created one backdoor account may have created others.

Phase 5 — Recovery

6. **Rebuild rather than clean.** NPT-WS01 held SYSTEM-level persistence across four mechanisms. Reimaging from a known-good baseline is the only defensible way to assert the host is clean. Cleaning in place is faster but leaves an unfalsifiable claim behind.
7. **Complete the scope of NPT-SRV01** before deciding its remediation path. A server rebuild carries higher operational cost, so the decision should follow evidence rather than precede it.
8. **Restore data from backups predating 22 April 2026, 04:00 UTC**, and validate backup integrity before restoration.
9. **Return hosts to production in stages**, with enhanced monitoring for the blocked indicators and for any recurrence of the persistence patterns.
10. **Monitor for at least 30 days** for reauthentication attempts from the blocked address or related infrastructure, and for the helpdesk account appearing from unexpected sources.

Phase 6 — Post-Incident Activity

6.1 Lessons Learned

- **Preparation gap — user reporting.** The user observed the attack in progress and went back to sleep. The intrusion succeeded during the hours between observation and report. Awareness training should treat unexpected authentication prompts as a reportable event, and reporting must be frictionless enough to use at 3am.
- **Preparation gap — detection coverage.** Repeated failed logons followed by a success from an external IP is a detectable pattern that should not have required a help desk ticket to surface. This is the highest-value engineering outcome of the incident.
- **Shared account exposure.** A shared 'helpdesk' account authenticating from the public internet represents an architectural weakness, not merely a password weakness. Shared support accounts should be individually attributable and restricted to internal sources.
- **Missing multi-factor authentication.** MFA on the helpdesk account would have defeated this intrusion at the first step, making it the single highest-return control.

6.2 Recommended Detection Engineering

- Alert on successful network logons from public IP addresses for any service or shared account.
- Alert on failed-logout volume followed by success from the same source within a short window.
- Alert on wmiprvse.exe spawning cmd.exe or powershell.exe — high-fidelity, low false-positive.
- Alert on executable creation in C:\Windows\Temp and comparable staging directories.
- Alert on local account creation followed by Administrators group modification within 60 seconds.
- Alert on service or scheduled task creation whose binary path resolves to a user-writable directory.

6.3 Outstanding Actions

#	Action	Priority
1	Retrospective hunt from at least 22 Apr 00:00 UTC — the NPT-SRV01 alert predates the stated focus window by ~4 hours	Immediate
2	Complete scoping of NPT-SRV01; determine whether the implant was deployed in another form	Immediate
3	Fleet-wide hunt for the implant hash, C2 domain, and backdoor account name	Immediate
4	Forensic analysis of the implant to determine capability and data access	High
5	Determine how the helpdesk credential was obtained and whether it was reused elsewhere	High
6	Review external exposure of authentication services	High
7	Assess whether Finance data exposure triggers notification obligations	High
8	Deploy the detection rules listed in 6.2	Medium

Prepared in accordance with NIST SP 800-61 Revision 2, Computer Security Incident Handling Guide. All indicators were recovered from Microsoft Defender for Endpoint Advanced Hunting telemetry.